

Cesium Hardware Root-of-Trust Authorization Plan

Consolidated test, production and decision plan for burning the SBC eFuse on Cesium AOSP 15 tablets at CVTE, then Malata

Product	Cesium tablet (iFitG520), MediaTek MT8371 / Genio 520 (tool reports MT8189), AOSP 15, A/B seamless update, battery-less console
Current build	VKC1_20260909 (software root of trust, fingerprint :user/dev-keys)
MP release candidate	VKC1_20260909 (the last OS build; no 0919 build exists. Source B's header referred to a VKC1_20260919 that was never produced)
Mass production	~3 Oct 2026 (three weeks from this revision)
Fused cohort	100 units already fused by CVTE (line trial, 30 July 2026), serials recorded by the factory-test fuse check
Revision	1.6 draft, 12 September 2026 (1.0 to 1.5 issued earlier the same day)
Owner	Allen Middleton (Tablet Engineer, ICON Health & Fitness)
Supersedes	Cesium Closed-Config Field Brick-Resistance Test Plan r0.4 (test content carried forward with its case IDs); Android 15 Virtual A/B & AVB 2.0 Resiliency Test Plan v2.0 (glitch matrix carried forward with errata); Remote eFuse MT8371 Feasibility Study (conclusion adopted); MediaTek Security 2.1 Software Root of Trust Report (three-way comparison adopted, probability figures reinterpreted)

Changes in revision 1.6. Financial model in Section 6.3 populated with the program assumptions of 100,000 tablets in the field at \$170 per tablet; the hardware-RoT premium is itemised term by term. Section 3.3 gains a CVTE deliverables checklist for releasing the 100-unit cohort, including the forced-download demonstration (P2, E5) that was not among the five items sent on 12 Sep. Section 2.1 records that the unsigned configuration is reference only and not a program option: all testing to date has run on software root of trust and the 2 October MP date does not permit a configuration change. Assumption 1 partly closed.

Changes in revision 1.5. Correction: there is no VKC1_20260919 build. VKC1_20260909 is the last OS build and the MP release candidate. The 0919 label was inherited from Source B's header and has been removed throughout. Consequences: the Day 19 "re-test on final build" reserve becomes conditional, triggered only if 0909 is re-signed by the G1 release-signing step or a K0 key decision; the schedule no longer has a build-arrival dependency; and the fused cohort's upgrade from its 30 July firmware to 0909 is its first counted OTA transition under Section 3.3.

Changes in revision 1.4. Three inputs from 12 September. (a) The 0909 fingerprint is confirmed as `iFit_Embedded/iFitG520/Cesium:VanillaIceCream/AP3A.240905.015.A2/VKC1_20260909:user/dev-keys`, and a separate analysis with CVTE certificate evidence reclassifies the tag from blocker to build hygiene: the OTA certificate, `platform.x509.pem` and the payload signature all carry the ICON certificate (O = Icon Health and Fitness, CN = ifit.com), not an AOSP test key. G1 is restated accordingly: the gate is a release-signing step separate from compilation with keys ICON holds; the tag is fixed as a side effect. (b) CVTE's message of the same day describes a production-line scripted fuse tool with per-unit logs, a build pipeline that signs `DA_BR.bin` and firmware at compile time and gates firmware generation on a hash match against `efuse_iFitG520.img` and the private key, and a factory test that hard-fails unfused units. This confirms the MediaTek root key and the platform keys are resident on CVTE's build system, and it means the factory test needs an unfused mode for the next batch (new I6). (c) ICON replied to CVTE: no eFuse programming on the next batch; five items requested (Section 8, items 23 to 27). Source G added.

Changes in revision 1.3. Program decision recorded: CVTE has already fused 100 units, and the intended posture is to field those serials as a tracked cohort while the remainder of mass production ships unfused until sufficient data exists. This is Option A with an existing cohort. Option B is withdrawn. New Section 3.3 defines the cohort protocol: release preconditions (fuse-map read-back, fingerprint and key checks, forced-download demonstration on a healthy fused unit), the data the cohort must generate (OTA transitions, not calendar time), the unfused control group, and the exit criteria that authorize fused production at CVTE and then Malata. Sacrificial and golden fused test units are now drawn from the 100. The key-rotation decision is flagged as fleet-splitting. Assumptions 23 to 25 added.

Changes in revision 1.2. Source F, the MediaTek MT8391/MT8371 Android 15 Secure Boot Developer Guide V1.1, ingested and used to verify Source E. Flag names, the CERT1/CERT2 chain and the DAA flow in Source E are confirmed verbatim. Two facts from the guide change the plan. First, BROM fallback to the second preloader copy is documented **for NAND only**; Cesium boots from eMMC, which is the likely reason `preloader_b` did not take over on the bricked first article, so E2 is rescoped from a pass/fail to a characterisation and R1's mitigation rests on E1 and E5 alone. Second, the eFuse configuration file carries a `Disable_Rom_Cmd` option that MediaTek "highly recommends" and that permanently disables BROM command mode; if it is set in `efuse_iFitG520.img`, forced download (E5) is impossible on every fused unit, which would also explain the no-enumeration brick. G7 now reads back that bit explicitly and a new Day 1 action inspects the fuse XML.

Changes in revision 1.1. Source E (software root of trust report) ingested. Section 2 rewritten as a three-way comparison (unsigned, software RoT, hardware RoT). The corrupt-preloader brick mode is now classified as **new with fusing**, because under software RoT the BootROM does not verify the preloader and still offers download mode. Case A0 is sharpened to read the preloader security flag and `sboot_state`. A key-freeze rule is added: any key rotation must complete before the first unit ships under either option, because the preloader is outside OTA scope. Three new source conflicts (7 to 9) and two new missing assumptions (19, 20).

0. Decision summary

1. Field fusing is ruled out. The feasibility study is adopted in full: eFuse writes on MT8371 are only possible from BROM/DA mode or a preloader self-blow, and self-blow via OTA on a battery-less unit with no hold-up supply is a brick-rate machine. Every Cesium unit is therefore either fused on the production line or never fused. There is no "ship open, close later" path. That makes the per-unit fuse decision permanent in both directions.

2. Hardware root of trust does not raise the probability that a bad OTA is applied. It changes what can be recovered afterwards, and it adds exactly one new brick mode. The question in the brief is answered in Section 2. On the A/B path (everything `update_engine` writes) a corrupt or truncated payload is rejected before any write regardless of fuse state, and slot fallback is fuse-independent. If the 0909 preloader is built with `ATTR_SB00T_ENABLE` (to be confirmed by A0), the software root of trust already enforces LK, TEE and AVB signatures, so a mis-signed image already halts boot today. The fuse adds exposure in four places, none of which a 30-day soak measures well:

- **The preloader itself becomes verified.** Under software RoT the BootROM does not check the preloader; a corrupt preloader drops to BROM download mode and is re-flashed with no authorization. Under hardware RoT the BootROM halts on a hash mismatch, which is what the bricked first article shows (no USB enumeration). This is the one failure mode that is genuinely new with fusing, and E1 plus E5 exist to close it.
- **Key and fuse-image mistakes** become permanent and batch-scale (wrong hash, dev key, leaked key).

- **Every recovery path narrows** to signed artefacts: signed DA, re-signed firmware, older rescue images rejected. Leaving DAA unblown (G7, G11) keeps this narrower than Source E's worst case.
- **Keys are frozen for the life of the fleet.** Source E's software-RoT brick mode is a key rotation that updates LK but not the preloader. Since the preloader is excluded from OTA (E1), rotation is impossible after shipment in **both** configurations. Any rotation must happen before lot 1 ships.

Those four are controlled by gates, custody and rehearsal before the first unit is fused, not by field time. This is good news for the schedule: the risks that actually differ between open and closed are front-loadable.

3. Program posture (decided): the 100 units CVTE has already fused are the field cohort; the remainder of mass production ships on software root of trust until the cohort has produced sufficient data. This is Option A in Section 3.1 with a cohort that already exists, and it matches Source E's own recommendation for 100 to 500 unit field trials. Option B is withdrawn. Section 3.3 turns "track those serials for a period of time" into a protocol, because calendar time on its own measures nothing about OTA brick risk. The cohort must:

- **Pass release preconditions before any unit reaches a customer:** fuse-map read-back on a sample including `Disable_Rom_Cmd`, fingerprint and key checks on that build, and forced BROM download demonstrated on one healthy fused unit.
- **Receive at least two full OTA transitions** with per-serial telemetry, alongside a tracked unfused control group receiving the same packages.
- **Exit on evidence, not elapsed days:** zero unrecoverable units, outcomes indistinguishable from the control group, E5 demonstrated, and the Group G key gates closed.

Two consequences are accepted with this posture. Every unfused MP unit is permanently unfused. And every unfused MP unit must carry an `ATTR_SB00T_ENABLE` preloader (A0-b), or the bulk of production ships with no boot-chain signature enforcement at all.

4. Four items must start today because they have the longest lead time and each one alone blocks fusing:

1. Revive bricked unit J26080143-0A00076 via forced BROM download (E5). If this cannot be shown, closed configuration is not accepted at all.
2. ~~Resolve the `dev-keys` fingerprint versus ICON certificates.~~ **Resolved 12 Sep as to which key:** the certificates are ICON's (G2 closed on 0909, the MP release candidate). **Open as to custody:** the tag means the keys are consumed at compile time on CVTE's build system. G1 is now "release signing in a step separate from compilation, with keys ICON holds", requested from CVTE as item 5 of the 12 Sep reply.
3. Key custody (G3, G5): AVB private keys (`img_prvk.pem`, `da_prvk.pem`, `root_prvk.pem`) were posted as Basecamp attachments to a 19-person distribution including ODM client accounts. Keys distributed that way cannot be considered in custody. Decide within 48 hours whether to rotate to an ICON-held key and regenerate `efuse_iFitG520.img` before any MP unit is fused. Rotation costs roughly 3 to 5 days of re-signing and re-test; not rotating means the fleet permanently trusts a key at least 19 people have handled. Whatever is decided, rotation must complete before the first unit ships under either option, because the preloader carries the root key (software RoT) or is verified against it (hardware RoT) and is outside OTA scope.
4. Written CVTE confirmation of exactly which partitions the OTA payload writes and that preloader/boot0 are never in scope (E1).
5. Open the eFuse configuration (`security/efuse/input.xml`) and the generated `efuse_iFitG520.img` and read the state of `Disable_Rom_Cmd`, `jtag_en` and `debug_en`. MediaTek's guide recommends `Disable_Rom_Cmd="true"` for high security; set, it permanently removes BROM command mode and therefore every USB recovery path including E5. If it is true in the image that

was burned on the first articles and the 100-unit trial, those units cannot be recovered by any documented procedure, and the fuse image must be regenerated before any MP unit is fused. This is the leading hypothesis for why the bricked unit does not enumerate.

1. Sources and reconciliation

Source	What it contributes	Trust and scope
A. Android 15 Virtual A/B & AVB 2.0 Resiliency Test Plan v2.0 (MediaTek app-note derived)	Glitch matrix PWR-01..04, USR-01, AVB-01; build and kernel configuration table; CTS/VTs module list; 1,000-iteration open-config pass criterion.	Trusted for generic AOSP 15 mechanism. Written for open configuration. Two premises do not hold on this part (below).
B. Cesium Closed-Config Field Brick-Resistance Test Plan r0.4 (two years of Basecamp record with CVTE and Malata)	Program history, 19-item risk register, groups A–N with STOP-SHIP and GATE badges, sample matrix, exit criteria, 16 open questions for the ODMs and MediaTek.	Trusted and platform-specific. Not yet issued to the ODMs. This document carries its case IDs forward unchanged so the two can be read side by side.
C. Remote eFuse Programming MT8371 Feasibility Study	Fuse programming modes; self-blow pipeline; field failure modes (3.7 V threshold, hash mismatch, magic-key mismatch, unreadable failure log). Verdict: not feasible for field deployment.	Trusted. Its conclusion is adopted; its "enable anti-rollback for field counters" recommendation is not adopted (see conflict 1).
D. Cesium 0831 Boot Log Analysis (this repository)	Corroborating evidence: keystore2 ROLLBACK_RESISTANCE_UNAVAILABLE; no reliable RTC, wall clock set to build time each cold boot.	Supporting only.

Source	What it contributes	Trust and scope
E. MediaTek Security 2.1 Software Root of Trust Report (MediaTek Secure Boot Developer Guide V1.1, Secure 2.1 Configuration SOP, eFuse Writer Guide)	Definition of software RoT: preloader built with <code>MTK_SEC_BOOT = ATTR_SBOOT_ENABLE</code> enforces CERT1/CERT2 verification of LK, TEE and AVB descriptors with the root public key compiled into the preloader (<code>sw_root_pubk.h</code>); BootROM does not verify the preloader while <code>SBC_EN = 0</code> . Contrast flag <code>ATTR_SBOOT_ONLY_ENABLE_ON_SCHIP</code> enforces only once fused. Three-way comparison of unsigned, software RoT and hardware RoT; recovery paths for each; recommendation of software RoT for 100 to 500 unit field trials.	Trusted for mechanism and configuration flags. Its bricking-probability percentages are conditional estimates without a cited measurement and are reinterpreted in conflict 7. The document is machine-generated from the cited MediaTek guides. Checked against Source F in revision 1.2: flag names, the CERT1/CERT2 chain, <code>oemkey.h</code> placement, key file names and the DAA flow are accurate. Its <code>sboot_state = 0x1</code> detail and the "anti-rollback software version check" step in the software-RoT flow do not appear in Source F and remain unverified.
F. MediaTek MT8391 MT8371 Android 15 Security Secure Boot Developer Guide V1.1 (MediaTek Confidential, watermarked to ICON, retrieved 30 Jul 2026)	Authoritative BROM, preloader, LK and TEE verification flow; <code>MTK_SEC_BOOT</code> / <code>MTK_SEC_USBDL</code> flag semantics (5.2.1); key generation and <code>oemkey.h</code> embedding into preloader, DA and LK (5.1); DAA AuthFile flow (4); eFuse <code>input.xml</code> options <code>Enable_SBC</code> , <code>Enable_DAA</code> , <code>Disable_Rom_Cmd</code> (7); preloader second-copy fallback stated for NAND (3.1 note).	Primary vendor source. Used to verify Source E and to correct two premises in Source B (see conflicts 10 and 11). Confidential: cite section numbers to the ODMs, do not reproduce.
G. 12 September 2026 inputs: (i) 0909 <code>ro.build.fingerprint</code> and the separate dev-keys analysis with CVTE certificate evidence (OTA cert, <code>platform.x509.pem</code> and payload signature share SHA-256 <code>61:7C:CC:3A: . . . 1B:BF</code> , subject O = Icon Health and Fitness, CN = ifit.com; <code>delta_generator</code> verification against the ICON public key passed; <code>ro.boot.verifiedbootstate=green</code> , <code>ro.boot.veritymode=enforcing</code>); (ii) CVTE message describing the production-line fuse tool, compile-time signing and hash gate, and the factory-test fuse check; (iii) ICON's reply declining fusing on the next batch	The tag is a build-configuration artefact (<code>build/make/core/tasks/build_tags.mk</code>) and not evidence of which key signed. The certificate evidence settles G2. It does not settle custody: CVTE's own description places the private keys in the compilation pipeline. One follow-up from the analysis carried into Section 8: confirm the 39 APKs not signed with the ICON platform certificate are all expected third-party apps.	

1.1 Conflicts between trusted sources and how this plan resolves them

#	Conflict	Resolution in this plan
1	Anti-rollback. Source A says MTK_SECURITY_ANTI_ROLLBACK = yes is supported and required; Source C recommends relying on it for field version management. Source B records MediaTek stating in Mar 2024 that it cannot be enabled on this project and CVTE reconfirming in Aug 2026 that it remains disabled on 8371. Source D shows the KeyMint side reports rollback resistance unavailable.	Treat anti-rollback as disabled and to stay disabled for MP (Group F). A signed known-good older build is then the fleet-wide escape hatch (F1), which matters more on a fused fleet than downgrade protection does. Source A case AVB-01 is rescoped to signature-based rejection only (F2); its "ARB counter check" pass criterion cannot be met. Obtain one written MediaTek statement to close the disagreement (open question 6). Agree a compensating control for signed-but-old pushes (open question 16).
2	Virtual A/B. Source A assumes copy-on-write snapshots and userspace merge (snapuserd, dm-user) throughout; roughly a third of its cases depend on this. Source B confirms A/B from the paired slot table (M1) but not the snapshot layer.	M2 and M3 run on Day 1. If virtual A/B is not enabled, PWR-02, PWR-04 and USR-01 are re-scoped to plain A/B slot writes rather than reported as failures.
3	Verity error handling. Source A corrects CONFIG_DM_VERITY_AVB to y for managed restart. Source B case M4 asks to confirm the verity-AVB immediate-invalidate option is not selected.	Do not edit kernel configuration on the basis of either document. The binding evidence is behavioural: M5 induces a single-block verity error on a sacrificial fused unit and must produce a controlled restart and slot fallback, never a loop or a brick. Record the actual defconfig and LK hashtree error mode alongside the result.
4	Battery threshold. Source C's 3.7 V cut-off applies to self-blow on battery. Cesium has no battery.	Irrelevant to field OTA (no self-blow ships). Relevant to the factory station: the burn depends entirely on the 12 V bench supply and the manual power sequence, so station power conditioning and interruption behaviour are tested (L2, I4).
5	Non-A/B boot chain. Source A treats non-A/B as deprecated and out of scope. Source B records that the one demonstrated brick on this program was a non-A/B boot stage (corrupt preloader_a, intact preloader_b did not fail over, no USB enumeration).	Group E is the highest-value group in this plan. E5 is the single stop-ship.
6	Iteration counts. Source A requires 1,000 consecutive passing iterations. Source B requires zero unrecoverable units over a 200-cycle randomised soak.	1,000 iterations on open units (cheap, automated, no scrap). 200 randomised interruptions on fused units, bounded by sacrificial hardware, with zero unrecoverable as the binding criterion.
7	Bricking probability figures. Source E estimates OTA bricking at 5 to 12 percent for software RoT and 25 to 40 percent for hardware RoT "if mismatched". Read as per-OTA rates these would make any OTA plan unshippable and would contradict Sources A and B.	Read them as P(brick given a key or hash mismatch has already been shipped) , which is what the wording says. The mismatch event is exactly what G1 to G6 and J1 prevent from ever leaving the build pipeline. The figures therefore quantify the cost of a gate failure, not the field rate of a gated fleet. They are not used as inputs to Section 6.3 until a measured source is found.
8	DAA state. Source E's hardware-RoT recovery case assumes both SBC_EN and DAA_EN are blown, so BROM refuses every unsigned Download Agent and recovery needs a signed da.auth or a MediaTek RMA certificate. Source B's plan blows SBC only and the SOP trace shows DA authentication disabled.	Cesium recovery is less constrained than Source E's worst case as long as G7 and G11 hold (only SBC set, DAA decision recorded, never blown in the same pass). Source E is the description of what Cesium becomes if DAA is ever blown without a demonstrated recovery path, which is why G11 is STOP-SHIP.

#	Conflict	Resolution in this plan
9	What "software root of trust" enforces on 0909. Source E: enforcement depends on the preloader build flag. <code>ATTR_SB00T_ENABLE</code> verifies LK, TEE and AVB regardless of fuse state; <code>ATTR_SB00T_ONLY_ENABLE_ON_SCHIP</code> verifies nothing until fused. Source B records both "mismatches are ignored" (Feb 2024) and "software AVB verifies bootloader/Android binding" (May 2026), which are consistent with different flags at different times.	A0 reads the flag from the 0909 preloader configuration and <code>sboot_state</code> from the console, then confirms behaviourally with a wrong-key LK. If 0909 is <code>ONLY_ENABLE_ON_SCHIP</code> , the open lot 1 under Option A ships with no boot-chain signature enforcement and the plan must require <code>ATTR_SB00T_ENABLE</code> for open units (new gate A0-b). If it is <code>ATTR_SB00T_ENABLE</code> , the brief's premise is correct and Section 2 stands as written. Confirmed against Source F 5.2.1 , which states the SCHIP flags enable secure boot "according to eFuse SBC field" and the plain flags enable it "forcedly without eFuse to verify SW secure boot flow first".
10	Preloader A/B failover. Source B case E2 expects a fused unit with corrupt <code>preloader_a</code> to boot from <code>preloader_b</code> , and open question 1 asks why it did not. Source F 3.1 note B states BROM fallback to the second preloader copy is supported if the external storage is NAND flash . Cesium boots from eMMC.	E2 and E3 are rescoped from pass/fail to characterisation: record whether eMMC boot1 fallback exists on MT8371 at all and obtain MediaTek's written answer. Until then, assume no preloader redundancy on this product. R1's mitigation is therefore E1 (preloader never in OTA scope, enforced by pipeline) plus E5 (forced BROM download proven), with no third leg.
11	BROM command-mode disable. Source B's fuse-map gate G7 lists SBC, DAA, JTAG and PTSB. Source F section 7 adds <code>Disable_Rom_Cmd</code> (also <code>brom_magic_cmd_mode_permanent_dis</code> in the preloader GFH config) and "highly recommends" setting it: BROM "cannot receive any commands to download, disable secure boot check, and so on anymore". Source E's hardware-RoT recovery column assumes DAA only.	If this bit is set, forced download does not exist and E5 cannot pass on any fused unit. G7 now reads it back explicitly and requires it unset . Day 1 action 5 inspects <code>input.xml</code> and the burned image. The observed no-enumeration brick is consistent with either a BROM halt on hash mismatch (Source E 5.3) or this bit being set; the two are distinguished by whether the forced-download button sequence produces enumeration on a fused, otherwise healthy unit (CLOSED-5).

2. Does hardware root of trust increase field brick risk?

The brief's hypothesis: the 0909 build already enforces a software root of trust, so a corrupt signature already risks a non-booting unit, and the hardware root of trust may add no brick risk at all.

With Source E in hand the hypothesis is **correct for the A/B update path and for everything the preloader verifies, provided 0909 is built with `ATTR_SB00T_ENABLE`**. It is **incorrect for the preloader itself, for recovery, and for key handling**. The Basecamp record contains both "signature mismatches are ignored" (Feb 2024) and "software AVB verifies bootloader/Android binding" (May 2026). Source E shows these describe two different preloader build flags, so which one 0909 carries must be read on Day 1 (A0), not inferred.

2.1 Three configurations (from Source E, applied to Cesium)

Dimension	Unsigned boot (<code>ATTR_SB00T_DISABLE</code>)	Software RoT (<code>ATTR_SB00T_ENABLE</code> , <code>SBC_EN = 0</code>)	Hardware RoT (<code>ONLY_ENABLE_ON_SCHIP</code> , <code>SBC_EN = 1</code>)
Root key anchor	None	Public key compiled into preloader (<code>sw_root_pubk.h</code>)	Hash of public key in OTP (<code>SBC_PUBK_HASH</code>)
Who verifies the preloader	Nobody	Nobody . BootROM loads it unchecked (Source F 3.1: secure boot flow "can be enabled by blowing <code>SBC_EN</code> ")	BootROM, in silicon: hash of <code>SBC_PUBK</code> from eFuse, key from NVM, then RSA over the preloader

Dimension	Unsigned boot (ATTR_SB00T_DISABLE)	Software RoT (ATTR_SB00T_ENABLE, SBC_EN = 0)	Hardware RoT (ONLY_ENABLE_ON_SCHIP, SBC_EN = 1)
Preloader redundancy	Second copy tried by BROM on NAND only (Source F 3.1 note B)	Same	Same. Cesium is eMMC: assume none until MediaTek confirms otherwise
Who verifies LK, TEE, AVB descriptors	Nobody	Preloader software, enforcing (sboot_state = 0x1)	Preloader, whose own integrity is now guaranteed
Behaviour on LK/TEE signature mismatch	Boots	Halts at preloader assertion	Halts at preloader assertion
Behaviour on preloader corruption or mismatch	BROM download mode	BROM download mode; re-flash preloader, no auth file	BROM halts. No enumeration observed on Cesium. Forced-download entry (E5) is the only path
USB flashing protection	Any DA	Any DA unless ATTR_SUSBDL_ENABLE; SOP trace shows DA auth disabled on Cesium	Signed DA if DAA blown; Cesium leaves DAA unblown (G7)
Key rotation	Re-flash	Re-flash preloader (not possible by OTA on Cesium, E1)	Impossible
Reversibility	Full	Full, by re-flash	None
Source E's recommendation	Bring-up only	100 to 500 unit field trials	Production shipping mode

The unsigned column is reference only. It is not a program option: all Cesium testing has run on software root of trust and the 2 October MP date does not permit a configuration change. The comparison that matters is the right two columns.

2.2 Failure modes, open versus closed

Failure mode	Software RoT (open, if ATTR_SB00T_ENABLE)	Hardware RoT (SBC fused)	Marginal risk from fusing
Corrupt, truncated or bit-flipped OTA payload (C1, C2)	Rejected by update_engine hash check before any write	Same	None. Fuse is not consulted.
Delta against wrong source build (C12)	Rejected before write	Same	None.
Package signed with wrong or test key (C3, C4)	Slot fails preloader/AVB check at boot; falls back to previous slot	Same	None on the mechanism, if fallback works on a fused unit (C5–C10). If 0909 is ONLY_ENABLE_ON_SCHIP, the open unit boots foreign code instead and security, not brick risk, is what changes.
Corrupt vbmeta, boot.img, hash tree in the inactive slot (C5–C7)	Fallback to good slot	Fallback to good slot	None, conditional on C5–C10 and M5.

Failure mode	Software RoT (open, if ATTR_SB00T_ENABLE)	Hardware RoT (SBC fused)	Marginal risk from fusing
Power loss during download, write, post-install, slot switch, first boot (D1–D9, PWR-01..04)	A/B protects; boots good slot	Same	None on the A/B mechanism. Slot-metadata behaviour (M6–M8) must be verified once; it is fuse-independent.
Panic before boot-success marker (C8)	Auto revert	Auto revert	None.
Corrupt non-A/B stage: preloader / boot0 (E2–E4)	Soft brick: BROM download mode, re-flash with any DA and any preloader. No second-copy fallback on eMMC (Source F)	Hard brick unless forced download works. BootROM halts on hash mismatch; observed on J26080143-0A00076. If Disable_Rom_Cmd is set, no download mode exists at all	High until E5 passes. This is the one new brick mode. Mitigation is contractual: OTA never writes preloader/boot0 (E1), and the fuse map leaves BROM command mode enabled (G7).
Key rotation that updates LK but not preloader (Source E 5.2)	Halts at preloader; recoverable by USB re-flash of preloader	Halts; recoverable only with signed artefacts; hash cannot change	Both fatal in the field because the preloader is outside OTA scope. Rule: keys are frozen before lot 1 ships.
Wrong key hash, dev key, or leaked private key burned (R2, R3)	N/A: re-flash preloader with new key	Permanent, fleet-wide	Critical and new. Only gates prevent it (G1–G6).
Depot re-flash of a failed unit (H1)	Any image, any DA	Signed DA and re-signed image; earlier rescue images rejected	Medium: cost and process, not probability. Less severe than Source E's case because DAA stays unblown.
Storage bit rot in active slot (C11)	Verity detects (AVB enforced by preloader)	Same	None if M5 passes.
Factory fuse write itself (L1–L8, I1–I5)	N/A	Manual, ordered, irreversible	Medium, line-side only. 100-unit CVTE trial with zero failures is encouraging, not sufficient. Malata has no fuse experience at all.

Conclusion. If 0909 enforces software RoT, fusing changes nothing about how an OTA is verified or how a slot falls back. It adds one brick mode (preloader), removes every unsigned recovery route, and makes key errors permanent. The financial exposure therefore moves from "unforeseen OTA bug" (bounded by staged rollout regardless of fuse state) to "preloader integrity, key custody, and recovery procedure" (bounded only by E1, E5 and the Group G gates). Source E's own recommendation, software RoT for field trials of 100 to 500 units and hardware RoT for shipping, is the same posture as Option A.

3. Authorization options and schedule

3.1 Options

Revision 1.3: Option A is the decided posture, with the 100 CVTE-fused units as the pilot ring (Section 3.3). Option B is retained in this table for the record only and is withdrawn.

	Option A (decided)	Option B (withdrawn)
MP lot 1	Software RoT, plus 25–50 unit fused pilot ring built by the MP-intent line process and placed at ICON-controlled sites	All units fused
Fusing authorization for CVTE production	First lot after Tier 0 + Tier 1 pass and pilot soak (K1–K3) completes	Day 18, if every Tier 0 STOP-SHIP and Tier 1 gate has passed
Compensating control	None needed; fused population is the pilot	OTA freeze on fused serials until Tier 3 passes. Backend must be able to target by fuse state (J4 telemetry).
Field exposure	Zero fused units in customer hands until proven	Full fused lot in customer hands with no proven fused OTA history; exposure bounded only by the OTA freeze and then by ring sizes
Security cost	Lot 1 customer units are permanently open; cannot be fused later	None
Schedule cost	Fusing slips one lot; MP date unchanged	None if gates pass; automatic fall-back to Option A if any Tier 0 gate fails
Financial note	Cost of unfused units is a security-posture and compliance question, not a replacement cost	Cost of a wrong call is replacement of every affected unit plus depot signed-flash cost; no software remedy

Because fusing is a line step and not a design change, deferring it costs one lot of security posture but no hardware. Fusing prematurely cannot be undone on any unit already shipped. Given the current state of the record (dev-keys fingerprint unresolved, bricked first article not yet revived, keys distributed through Basecamp, preloader failover unexplained), Option A is the default and Option B must be earned.

3.2 Three-week schedule to MP

Days	Track	Content	Exit
1–2	Paperwork and baseline	G1, G2 on 0909; G3 custody decision; E1 written partition scope; M1–M4; N1, N2, N10; A0 open-config signature baseline; send open questions 1–16 to CVTE, Malata, MediaTek in one letter	Anti-rollback, virtual A/B and key posture known; test scope fixed
1–10	Brick recovery (long pole)	E5 on BRICK-1 with CVTE/MediaTek guidance under both chip designators; document exact button, timing and tool version	BRICK-1 boots a signed build, or closed config is not accepted
2–6	Open units (5)	C1–C13 rehearsal; D1–D9 and PWR-01..04, USR-01 at 1,000 automated iterations; F1–F3	Every case ends in a booting unit; behaviour baselined
4–10	Fused sacrificial (5 + spares)	E2–E4, E6; C1–C13 five times each; D7 200-cycle randomised soak; D8 brown-out; M5 verity error; N3 attestation; G4 hash regeneration; G7 fuse map read-back; G9 userspace fuse-write attempts	Zero unrecoverable; every failure mode has a recovery path
8–14	CVTE line	L1–L8 and I1–I5 witnessed by ICON; G10 build audit; H1–H5 depot at CVTE and at the US service site including a full-image profile (R19)	Station interlocked; per-serial trace; depot proven at two sites
12–18	Release engineering	J1–J5: pipeline signature gate, rings at 0.1 / 1 / 10 / 100 percent, automatic halt, kill switch, CDN integrity, telemetry incl. fuse state	Bad build halted in a lab ring
1–10	Cohort preconditions	P1 fuse-map read-back on ten of the 100; P2 forced download on a healthy fused unit; P3 fingerprint, certificates, attestation on the cohort build; P4 key decision; P5 backend records; P6 software parity	Cohort cleared for ICON-controlled placement
10 onward	Cohort field (Section 3.3)	ICON-controlled ring of 15 to 20 takes the first OTA; customer placement of the remainder after that; K2 two OTA transitions; K3 two depot recoveries; control group tracked in parallel	X1 to X4 (completes after MP, likely 60 to 90 days)

Days	Track	Content	Exit
19	Re-test only if re-signed	0909 is the MP release candidate, so no separate final-build re-test is scheduled. If G1 (separate release-signing step) or a key decision (K0) produces a re-signed 0909, re-run G2, G4, N3, B1, B2, C3, C5, D2, D4, F1, M5 on that artefact; reserve 3 days for it. Any re-sign changes hashes; nothing tested on the compile-signed 0909 transfers automatically	Final artefact pairing signed off (L5)
18	Go / No-Go	Tier 0 and Tier 1 review. Option B only if all pass.	Signed decision record
21	MP start	Option A or B per decision	
MP + 5 to 10	Malata	Tier 2 transfer and witnessed first-article run before Malata's first fused lot	

With 0909 confirmed as the release candidate, the schedule no longer waits on a new build; the only re-test trigger is a re-signed artefact from the G1 or K0 decisions. With Option B withdrawn, the Day 18 decision is narrower: it authorizes release of the fused cohort to the field and confirms the unfused MP configuration (A0-b), not fusing of production.

3.3 Fused field cohort protocol (the 100 CVTE units)

The cohort exists, so the question is not whether to build a pilot but how to extract a decision from it. "Track the serials for a period of time" is restated below as preconditions, a measurement, a control, and exit criteria.

Release preconditions. None of the 100 goes to a customer until all of these are on file.

#	Precondition	Why
P1	Fuse-map read-back on at least ten of the 100: <code>sbcs_en</code> set, <code>sbcs_pub_key_hash</code> matches the ICON-verified hash (G4), <code>Enable_DAA</code> , <code>Disable_Rom_Cmd</code> , <code>jtag_en</code> , <code>debug_en</code> recorded. Cross-check against the <code>input.xml</code> CVTE used (open question 20)	The image that was burned is unverified. If <code>Disable_Rom_Cmd</code> is set, the cohort has no USB recovery path and a field brick is a board swap
P2	Forced BROM download demonstrated on one healthy unit from the cohort, then E5 on BRICK-1	Proves the recovery path exists for this exact fuse map before customers depend on it
P3	G2 and N3 on the cohort's build: certificate chain resolves to ICON (closed on 0909, repeat on the cohort's actual firmware), key attestation reporting verified and locked against the burned hash. G1 (release signing step) is not a precondition for the cohort, since re-signing would not change the fused hash	The 30 July build predates the dev-keys review; the cohort may not be on 0909
P4	Key-rotation decision recorded (G3, K0). If ICON rotates, the cohort keeps its own signing chain for life or is withdrawn; if not, the accepted residual risk of the Basecamp-distributed key is signed off	The cohort's hash is fixed. Rotation splits the fleet into two signing chains permanently
P5	Per-serial record for every cohort unit in the OTA backend with fuse state, fingerprint, slot and the depot routing flag (J4)	Depot must never attempt an unsigned flash on a cohort unit, and OTA rings must be able to target by fuse state
P6	Cohort units run the same OTA client, telemetry agent and release as the unfused MP units	Otherwise cohort and control are not comparable

Allocation of the 100. Not all of them should go to customers.

Allocation	Qty	Use
Sacrificial and golden test units	7	CLOSED-1..7 in the sample matrix (Groups C, D, E, H, M, N3). Replaces the need to build new fused units
ICON-controlled field units	15 to 20	Offices, employee homes, test gyms. First ring for every cohort OTA; depot rehearsal candidates (K3)

Allocation	Qty	Use
Customer field units	remainder (roughly 70 to 75)	Normal retail placement, released only after P1 to P6, and only after the ICON-controlled ring has taken the first OTA cleanly

CVTE deliverables to release the cohort (r1.6). Items marked "sent" were in ICON's 12 September reply; the rest are still to be requested.

#	Deliverable	Plan reference	Status
C1	eFuse read-back log per serial for all 100, plus the <code>input.xml</code> and preloader GFH configuration used to build <code>efuse_iFitG520.img</code>	P1, G7	Sent (item 3)
C2	Demonstrate forced BROM download mode on one healthy fused unit, then recover J26080143-0A00076 with a signed build. Video plus console trace, with the exact button, hold timing and tool version	P2, E5	Not yet requested
C3	MTK_SEC_B00T and MTK_SEC_USBDL values in the 0909 preloader makefile	A0, A0-b	Sent (item 2)
C4	Root public key (<code>root_pubk.der</code>) so ICON can regenerate <code>sbc_pub_key_hash</code> and match it to read-back	G4	Not yet requested
C5	Signed <code>DA_BR.bin</code> , signed 0909 image, pinned SP Flash Tool and driver versions, and a written depot procedure including a full-image profile, not only the boot-chain profile	H1, H4, R19	Not yet requested
C6	Firmware version currently on the 100, and confirmation that the 0909 OTA package (full or incremental) applies to it	P6, K2	Not yet requested
C7	Seven of the 100 released to ICON as CLOSED-1..7 for destructive testing	Sample matrix	Not yet requested
C8	Same root, image, DA and platform keys for the cohort and the unfused batch	P6	Sent (item 4)

ICON-side prerequisites: N3 key attestation on a cohort unit, P5 backend records with fuse state per serial, and the 0909 OTA applied to the ICON-controlled ring before any customer placement.

Measurement. Field time produces no data unless updates are pushed. The cohort must receive at least two full OTA transitions (K2), one of which should be the transition every MP unit will also take. Per serial and per transition, record: download outcome, install outcome, slot switch, boot-success marker, boot attempts before success, verified-boot state after update, and any depot or RMA event with its recovery result. Naturally occurring power interruptions on a battery-less console are part of the exposure and should be counted from boot-reason telemetry.

Control group. The unfused MP units are the control. Track a matched sample (at least the same size as the customer cohort, preferably ten times larger) through the same OTA transitions with the same telemetry. Since fusing does not change how an OTA is verified or how a slot falls back (Section 2), the two populations should be indistinguishable. Divergence is the finding.

What the cohort can and cannot show. With roughly 100 units and two transitions, zero failures bounds the fused OTA brick rate at about 1.5 percent at 95 percent confidence. That detects a systematic defect in the fused path. It does not detect a rare one, and it says nothing about key custody, depot readiness or line controls, which remain gated by Tiers 0 to 2 regardless of cohort results. The cohort retires R13 (no organisational experience) and R5 (fallback on a fused unit never measured); it does not retire R1, R2 or R3.

Exit criteria for authorizing fused production.

#	Criterion
X1	At least two OTA transitions completed across the cohort with zero unrecoverable units
X2	Cohort update-outcome distribution indistinguishable from the control group on the same transitions

#	Criterion
X3	E5 passed: forced BROM recovery demonstrated on a bricked fused unit
X4	At least two cohort units recovered at a depot using only the published procedure (K3, H1)
X5	All Tier 0 gates closed, including G3/K0 key decision and G7 fuse map with <code>Disable_Rom_Cmd</code> unset
X6	Tier 1 line controls passed at CVTE; Tier 2 at Malata before Malata's first fused lot
X7	Decision recorded with the accepted count of permanently unfused units shipped during the cohort period

Minimum elapsed time is set by X1, not by a calendar. Two transitions at a normal release cadence is likely 60 to 90 days.

4. Authorization gates by tier

Gate identifiers are from Plan B (r0.4). **STOP-SHIP** halts the closed-configuration decision. **GATE** must pass before a later group's results are credited or before a line runs.

Tier 0. Irreversibility gates: before any MP unit is fused, at any ODM

ID	Gate	Pass criterion	Owner
G1 (restated r1.4)	STOP-SHIP Release signing	The MP build is signed in a release step separate from compilation, using platform and OTA keys ICON holds. <code>ro.build.tags</code> reads <code>release-keys</code> as a consequence. The tag alone is neither necessary nor sufficient: on 0909 it reads <code>dev-keys</code> while every certificate is ICON's	CVTE (pipeline), ICON (keys)
G2	STOP-SHIP Certificate chain	<code>otacert</code> , <code>platform.x509.pem</code> and the AVB image key all resolve to the ICON certificate; none matches an AOSP test key. Closed on 0909 (SHA-256 <code>61:7C:CC:...:1B:BF</code> , O = Icon Health and Fitness). Repeat on any re-signed artefact	ICON
G3	STOP-SHIP Key custody	ICON holds or escrows root, img and DA private keys in an HSM or restricted escrow; keys removed from Basecamp; custody documented; decision on rotation recorded	ICON
G4	STOP-SHIP Fuse hash	ICON independently regenerates <code>sbc_pub_key_hash</code> from the public key and matches it to read-back from a fused unit	ICON
G5	STOP-SHIP Leak response	Tabletop for signing-key leak after MP; limits accepted in writing because OTP cannot be re-keyed	ICON security
G6	STOP-SHIP ODM signing process	Who signs, with which key, under what approval, how a rogue ODM build is detected	CVTE, Malata, ICON
G7	STOP-SHIP Fuse map	Read back from an MP-process unit and from the burned first articles: only SBC set. DAA, JTAG-disable, PTSB and <code>Disable_Rom_Cmd / brom_magic_cmd_mode_permanent_dis</code> unblown. Cross-check against <code>input.xml</code> and the GFH config used to build <code>efuse_iFitG520.img</code> . A set <code>Disable_Rom_Cmd</code> bit removes every USB recovery path and blocks fusing outright	CVTE, ICON
E2 (rescoped)	Characterisation	Corrupt <code>preloader_a</code> on a fused unit and on an open unit. Record whether BROM tries the second copy on eMMC. Source F documents second-copy fallback for NAND only, so a fail here is information, not a defect	Test lead, MediaTek written answer
G8	STOP-SHIP Host- side only	Written CVTE and MediaTek confirmation that no runtime, bootloader or TEE path can program SBC, DAA, JTAG or PTSB	CVTE, MediaTek
G9	STOP-SHIP Userspace write attempt	On a non-fused sacrificial unit, every attempt (factory app, init service, adb, privileged app, fastboot, recovery) fails; fuse state unchanged	Test lead

ID	Gate	Pass criterion	Owner
G10	STOP-SHIP Build audit	No efuse images, write scripts, DA binaries, private keys or factory-test fuse check in the shipping user build	CVTE, audited by ICON
G11	STOP-SHIP DA authentication posture	Signed decision on the intended shipping state of the download path (R17). Under no circumstances is the DAA fuse blown in the same pass as SBC	ICON
E1	STOP-SHIP OTA partition scope	Written CVTE confirmation that preloader, boot0, DA, TEE and SCP/DSP are never in an OTA payload, and the release pipeline enforces the exclusion	CVTE
E5	STOP-SHIP BROM recovery	J26080143-0A00076 and one freshly bricked fused unit recover via forced download and boot a signed build	Test lead, CVTE
C, D	STOP-SHIP Zero unrecoverable	Groups C and D complete on fused units including the 200-cycle soak with zero unrecoverable units	Test lead
M3–M8	GATE Configuration	Merge mechanism identified; verity error mode behavioural (M5); slot metadata survives interruption; factory reset refused during merge	Test lead
N1, N2, N10	GATE Prerequisites	Boot-control HAL and snapshot suites conform; fused userdebug build signed with release keys is available so fused-vs-open comparison is executable	CVTE, test lead
N3	STOP-SHIP Attestation	Key attestation on a fused, locked, release-signed unit reports verified and locked against the burned hash	Test lead
N11	STOP-SHIP GSI window	Written confirmation nobody downstream relies on generic-system-image evidence, which ends permanently at fusing	ICON
A0 (new)	Baseline	Read MTK_SEC_B00T and MTK_SEC_USBDL from the 0909 preloader project configuration and sboot_state from the preloader console. Then on an open 0909 unit flash a wrong-key LK and a wrong-key vbmeta; record halt, warning or boot. Result settles Section 1.1 conflict 9	CVTE (config), test lead (behaviour)
A0-b (new)	STOP-SHIP for open units under Option A	Any unit shipped unfused must carry a preloader built with ATTR_SB00T_ENABLE, verified by A0 on the shipping build. An unfused unit built with ONLY_ENABLE_ON_SCHIP has no boot-chain signature enforcement at all	CVTE, ICON
K0 (new)	STOP-SHIP Key freeze	Root, image and DA keys are frozen before the first unit ships under either option. Rotation after shipment requires a preloader update, which E1 excludes from OTA. Recorded as a signed decision alongside G3	ICON

Tier 1. CVTE production-line authorization

ID	Gate	Pass criterion
L1	Ten open sacrificial units through the SOP as written; per-serial console trace, chip ID, random ID, DA authentication state archived	All reach completion message
L2 GATE	Interrupt fuse write at the 12 V step and mid-transfer, five units each	Each unit is unfused-and-rerunnable or fused-and-flashable; none unfused-but-passed, none partial
L3 GATE	Attempt to flash production firmware to a unit whose fuse write failed or never ran	Station refuses and quarantines; ordering enforced by tooling
L4 GATE	DA authentication state recorded on every unit; shipping posture decision on file	Matches G11
L5 GATE	Fuse image is the ICON-approved artefact, hash-matched to the G4 key; authoritative build label for fuse image and firmware resolved in writing	Hash match per serial
L6	Re-run fuse write on an already-fused unit	Idempotent or cleanly refused; never a changed hash

ID	Gate	Pass criterion
L7	Station pinned: flashing tool version, DA, USB drivers, image package	Versions frozen and change-controlled
L8	Time-and-motion including driver-install fallback	Cycle time known; no line pressure toward shortcuts
I1	ICON witnesses a live scripted run	No manual key entry; step cannot be skipped
I2	Advance an unfused unit through factory test	Hard stop
I3	Per-serial fuse write and read-back exported	Auditable by ICON
I4	Power loss or cable pull at the station mid-write	Detected by read-back; quarantined
I5	Yield and scrap over a 500-unit run	Scrap rate accepted in writing before MP release
I6 (new r1.4)	Factory test has an unfused mode for the next batch: reads and logs eFuse state per serial, does not require <code>sbc_en</code> . The fused-required mode is re-enabled only by the written fusing authorization	Every unfused MP unit carries a factory-test record proving it is unfused; the two modes cannot be selected by an operator
Note	CVTE's 12 Sep message describes the line tool: worker opens the tool, selects <code>flash.xml</code> , the tool writes <code>efuse.img</code> , powers on, enters factory test, and stores a log per run; <code>DA_BR.bin</code> and firmware are signed at compile time and firmware generation is gated on a hash match against <code>efuse_iFitG520.img</code> . This is the evidence base for L1, L3, I1 and I3, to be witnessed rather than accepted on description. The earlier SOP was an R&D guide, not the line procedure	
H1 GATE	Depot re-flash of a fused unit with signed DA and signed build at CVTE and at the US service site, using a full-image profile and not only the boot-chain profile (R19)	Succeeds at both; time and cost recorded
H2– H5	Recovery/fastbootd reachable and sideload works; factory reset from corrupt userdata recovers; signed-DA custody documented; field-service decision tree validated on real failed units	All pass

Tier 2. Malata production-line authorization

Malata has no fuse-station history on this program. Tier 2 is a transfer, not a re-derivation.

Requirement	Pass criterion
Transfer package from CVTE	Same fuse image (hash verified by ICON), same pinned tool, DA, driver and package versions (L7), same scripted station and interlock, same factory-test gate
No key material transferred outside controlled channels	Signed DA and any signing artefacts delivered per H4; nothing via project tools or email
First-article read-back	Ten Malata fused units: A1, A6, G4, G7 read-back verified by ICON; hash identical to CVTE units
Witnessed line run	I1–I5 and L1–L3, L5, L6 repeated on the Malata line with ICON present or on recorded video with logs
Depot	H1 at Malata's service path
Decision	Malata fusing authorized only after CVTE has shipped at least one fused lot with no fuse-attributable field return

Tier 3. Authorization to push production OTA to fused units

Requirement	Pass criterion
J1	Pipeline gate verifies every published package against the fused key chain; unsigned or wrong-key packages cannot publish
J2	Rings at 0.1, 1, 10, 100 percent with automatic halt on boot-success regression; demonstrated on a deliberately bad build in a lab ring
J3	Kill switch stops downloads within the defined interval during a live rollout
J4	Telemetry reports slot, fingerprint, verified-boot state, fuse state and update outcome per serial; bad rollout visible before the next ring
J5	Same build published twice with differing hashes is blocked
K1–K3	30-day fused pilot, at least two full OTA transitions, two random depot recoveries, zero unrecoverable
F1 on 0909	Signed older build flashes and boots on a fused unit: the fleet escape hatch is proven on the shipping build

Until Tier 3 passes, fused units in the field receive no OTA. This is the control that makes Option B tolerable and it costs nothing under Option A.

5. Consolidated test plan

Test content is Plan B groups A–N with Plan A's glitch matrix mapped in. Only additions and changes to Plan B r0.4 are listed here; unchanged cases are referenced by ID.

5.1 Sample matrix

Group	Qty	Configuration	Use
OPEN-1..5	5	Not fused, 0909	Control; every destructive case rehearsed here first; 1,000-iteration automated glitch matrix; A0 baseline
CLOSED-1..2	2	Fused	Sacrificial: preloader and boot-chain negative tests (E2–E4, E6). Assume total loss
CLOSED-3..4	2	Fused	C group ×5, D soak, M5 verity, depot rehearsal
CLOSED-5	1	Fused	Golden reference; never negative-tested; fuse read-back and performance baseline
CLOSED-6..7 (added)	2	Fused	Spares for the 200-cycle soak and for the fresh brick required by E5
BRICK-1	1	Fused, unbootable	J26080143-0A00076, E5 acceptance vehicle
USERDEBUG-F (added)	1	Fused, userdebug signed with release keys	Required by N10 for VTS on a fused unit; is itself a key-custody request
COHORT (r1.3)	100 total, 7 of which are CLOSED-1..7 above	Fused by CVTE on 30 July	Section 3.3: 15 to 20 ICON-controlled field units, roughly 70 to 75 customer units after preconditions P1 to P6
CONTROL (r1.3)	≥ customer cohort size, preferably 10×	Unfused MP units, ATTR_SB00T_ENABLE preloader	Same OTA transitions and telemetry as the cohort; the comparison population for X2

5.2 Additions and changes to Plan B r0.4

ID	Change	Reason
A0 (new)	Read preloader security flags and <code>sboot_state</code> ; wrong-key LK and wrong-key <code>vbmeta</code> on an open 0909 unit	Source E shows enforcement depends on the build flag. Settles whether the brief's premise holds and whether open lot 1 units under Option A enforce anything
A0-b, K0 (new)	Open units must be <code>ATTR_SB00T_ENABLE</code> ; keys frozen before first shipment	Source E section 5.2 brick mode (LK re-keyed without preloader) is unrecoverable by OTA on Cesium in either configuration
E2, E3	Rescoped to characterisation. Add the open-unit control: corrupt <code>preloader_a</code> on an OPEN unit and record whether BROM download mode enumerates and whether the second copy is tried	Source F documents second-copy fallback for NAND only; Cesium is eMMC. Source E predicts a soft brick on open units and a halt on fused units. The open case proves the preloader mode is new with fusing rather than pre-existing
E5	Add: run the forced-download button sequence first on CLOSED-5 (healthy fused unit) and confirm BROM enumerates before trying it on BRICK-1	Separates "the bricked unit is unreachable" from "BROM command mode is fused off on every unit" (conflict 11)
G7	Add <code>Disable_Rom_Cmd</code> , <code>jtag_en</code> , <code>debug_en</code> to the read-back and to the <code>input.xml</code> audit	Source F section 7 and 5.4
A7 (new)	OTA client behaviour with the wall clock at build time (no RTC): TLS validation of the OTA endpoint, package timestamp checks, before NTP sync	Source D shows every cold boot starts at build time. An OTA that fails or a certificate rejected as not-yet-valid is a field-visible failure mode independent of fusing but exposed by any OTA plan
N6 emphasis	Health HAL on a battery-less unit reports a sane state; <code>update_engine</code> minimum-battery policy verified	Tool reports <code>battery_voltage 0</code> ; an update client that refuses to start, or starts when it should not, is plausible
D8	Brown-out via programmable DC source sweep, not only clean cut	A sagging console supply is more likely than an instant drop
E5	Add: document the exact button, hold timing, tool version, and whether it is reachable without opening the enclosure	Defines hard versus soft brick for this product (Section 4.3 of Plan B)
F1	Must be run on the exact 0909 artefact that ships, and repeated if it is re-signed	Fleet escape hatch must be proven on the shipping artefact
J4	Add fuse state to fleet telemetry	Mixed fleet under Option A; OTA freeze under Option B; depot routing
K1	Pilot sites are ICON-controlled (offices, employee homes, test gyms), not customers	Zero fused customer units until soak completes
Glitch matrix	PWR-01..04 and USR-01 run at 1,000 iterations on open units; 200 randomised on fused; AVB-01 rescoped to F2	Reconciles Source A and B criteria; anti-rollback unavailable
Re-test set	G2, G4, N3, B1, B2, C3, C5, D2, D4, F1, M5 repeated on 0909 only if it is re-signed (G1 release step or K0 key decision)	Any re-sign invalidates hash-dependent results; no new build is expected

5.3 Instrumentation and records

Per Plan B 4.2, plus: per-serial fuse state in the backend, programmable DC source logs correlated to `update_engine` phase, and the exact SP Flash Tool, DA and driver versions frozen at L7 recorded in every test artefact.

6. Production plan

6.1 Line sequence (both ODMs)

1. Board in BROM/preloader download mode over mini-USB, 12 V applied only after write-efuse is issued (SOP order).
2. Station script writes `efuse_iFitG520.img`; `CMD:WRITE-EFUSE` command execute succeeded logged against serial.
3. Read-back: `sbc_en` set, `sbc_pub_key_hash` equals the ICON-approved hash; DAA, JTAG, PTSB unblown. Any other outcome quarantines the unit; the station will not proceed.
4. Signed production firmware flashed; Download 0k logged against serial.
5. Factory-test application hard-gates on fuse status. A unit with the wrong state cannot progress.
6. Per-serial record exported to ICON: serial, station, fuse read-back, fingerprint, slot suffix, factory-test pass.
7. Under Option A, fused and unfused units carry distinguishable labelling and the backend records fuse state per serial. Depot and RMA route by that field.

6.2 Depot and RMA

- Two proven sites before the first fused lot (H1): one at the ODM, one in the US.
- Full-image recovery profile validated, not only the boot-chain profile in the SOP (R19).
- Signed DA custody documented and distributed only through controlled channels (H4).
- Spare-board inventory must be fuse-state matched to the units it repairs.
- Field-service decision tree published: symptom, recovery action, escalation (H5).

6.3 Financial model (r1.6)

Program assumptions. 100,000 tablets in the field. \$170 per tablet. Fleet value at risk \$17.0M.

Placeholders, to be replaced when known: depot recovery including two-way shipping \$50 per unit; field replacement logistics \$50 on top of the tablet; boot0 storage corruption 0.05 percent per year; fuse-station scrap 0.1 percent (the 100-unit trial had zero; 15 measures it over 500).

Fusing does not change the OTA failure probability. It changes the recovery cost per incident, adds one brick mode, and adds one unbounded tail. Term by term:

Exposure term	Software RoT (unfused)	Hardware RoT (fused)	Delta from fusing
A/B OTA failure: payload rejected or slot falls back	Recovers in place. \$0	Same	\$0
Bad OTA reaching a ring before automatic halt: 0.1 / 1 / 10 percent	100 / 1,000 / 10,000 units affected. If depot-recoverable: \$5k / \$50k / \$500k. If not: \$22k / \$220k / \$2.2M	Same unit counts	\$0 if recoverable; otherwise see next row
Boot-chain brick (preloader, or vbmeta chain failure with no fallback)	Soft brick. USB re-flash at depot, about \$50	Hard brick unless E5 works. Replacement \$170 plus \$50 logistics	About \$170 more per incident. Occurs only if OTA writes the preloader (excluded by E1) or storage corrupts boot0
Storage failure in boot0 at 0.05 percent per year	50 units, about \$2,500 per year	50 units, about \$11,000 per year	About \$8,500 per year
Systematic key or fuse-image error on the fused population (wrong hash, <code>Disable_Rom_Cmd</code> set, key mismatch)	Not applicable: re-flash	Whole fused population lost. \$22M if all 100k fused. \$22,000 if only the 100-unit cohort	The unbounded term. The cohort posture caps it
Fuse station scrap at 0.1 percent	\$0	100 units per 100k built, \$17,000	\$17,000 per 100k
Depot tooling: signed DA custody, pinned tool, two sites	Existing depot	One-off setup, low tens of thousands	Fixed, small

Exposure term	Software RoT (unfused)	Hardware RoT (fused)	Delta from fusing
Key custody: HSM or escrow, release-signing step	Required anyway for G1	Same	\$0 delta
Line cycle time for the fuse step	\$0	L8 measures it; CVTE's scripted tool makes it a single operator action	Small per unit

Reading the table.

- The largest term, a bad OTA reaching a large ring, is the same on both configurations and is bounded only by staged rollout (J2) and the kill switch (J3). Neither the fuse nor the cohort changes it. This is where iFIT's stated fear of "unforeseen OTA issues" actually lives, and Group J is the control.
- Fusing adds roughly one tablet's cost per boot-chain brick. With the preloader excluded from OTA, boot-chain bricks come only from storage failure and are rare. Over a year on 100k units this is in the low tens of thousands of dollars, provided E5 works.
- Fusing introduces the one unbounded term. With the 100-unit cohort it is about \$22,000. With all of production it is the fleet. That is the quantitative case for the decided posture.
- If E5 does not pass, or `Disable_Rom_Cmd` is found set, every boot-chain brick on a fused unit is a \$220 event with no recovery, and the systematic term has no cap. That is why both are stop-ship rather than risks to be priced.

Not quantified here. The security value of hardware RoT for a kiosk console (physical re-flash, OS replacement, content protection, EN 18031 evidence). The true cost of a field replacement on an installed console, which likely exceeds the \$50 placeholder. The MP OTA cadence, which sets how many times per year the ring cap is tested.

Unsigned boot is not a program option. All testing has run on software root of trust and the 2 October MP date does not permit a configuration change. The unsigned column in Section 2.1 is a reference from Source E only.

7. Background assumptions that are missing or unstated

These are needed either to run the plan or to make the Option A / B decision. None of them is answered in the three sources.

Commercial and compliance

1. **Partly closed r1.6:** 100,000 tablets in the field at \$170 per tablet. Still needed: the true cost of a field replacement on an installed console (service call, shipping, swap), the depot recovery cost per unit, warranty terms, and the planned OTA cadence. Section 6.3 uses \$50 placeholders for the first two.
2. Whether Cesium ships into the EU and whether the EN 18031 assessment accepts a software root of trust. Xenon passed NIST 8259 with software RoT. If the compliance body requires hardware RoT, Option A's "permanently open lot 1" has a compliance cost, not only a security-posture cost.
3. The threat model the fuse is meant to close. For a kiosk fitness console, physical-access OS replacement, content and DRM, and brand protection are different threats. Remote threats are already covered by signed OTA on the open configuration. This decides whether shipping any unit unfused is acceptable.
4. Who signs the fuse authorization for CVTE and for Malata, and whether the MP line can start unfused and switch to fused mid-lot. If it can, the "three weeks" deadline applies to the line start and

not to the fusing decision, which relieves the schedule considerably.

Keys and artefacts

1. Whether the private keys posted to Basecamp are the production keys, whether ICON has an HSM or escrow available now, and whether the ODMs will accept a key rotation and `efuse_iFitG520.img` regeneration inside the schedule.
2. Whether a fused userdebug build signed with release keys will be produced (N10). Without it, VTS on a fused unit and the fused-versus-open comparison cannot run.
3. Whether Cesium licenses Google Mobile Services. This determines whether GTS applies and which suites are available (Plan B Group N).
4. Which build label is authoritative for the fuse image and firmware (VKC1_20260727 versus 20260729 ambiguity) and who signs off the pairing (L5).

Platform behaviour

1. Whether the OTA payload ever includes preloader, LK, TEE or SCP firmware (E1). This is the single written confirmation with the highest value in the plan.
2. Why `preloader_b` did not take over on the bricked first article, and the exact boot0 failover logic on a fused MT8371.
3. Whether the forced-download button is reachable on the assembled console without disassembly. This defines hard versus soft brick for the product.
4. Whether the console power supply has any hold-up capacitance and whether the user can remove power at any instant (mains switch, unplug). Determines how realistic D8 brown-out is relative to a clean cut.
5. How the OTA client behaves with the wall clock set to build time on every cold boot (no RTC) before NTP sync, and whether `update_engine` enforces a minimum battery level on a unit that reports zero battery voltage.
6. The agreed compensating control against a signed-but-old image being pushed as an OTA, given that anti-rollback cannot be enabled on this part.
7. The intended shipping posture for download-agent authentication (R17). An unauthenticated download path is what makes depot recovery cheap and what lets anyone with USB access re-flash or read partitions. This must be a recorded decision, and it interacts with the EN 18031 physical-access assessment.

Operations

1. Whether a US service site exists today with Windows hosts, the pinned SP Flash Tool version and a custody path for the signed DA.
2. How the backend, depot and RMA will handle a mixed fused and unfused fleet if Option A is chosen, and how an OTA freeze by fuse state would be implemented if Option B is chosen.
3. Malata's readiness: the 100-unit trial on 30 July was a CVTE run. Malata has not fused a unit on this program.
4. Which preloader security flag the 0909 build carries (`ATTR_SB00T_ENABLE` versus `ATTR_SB00T_ONLY_ENABLE_ON_SCHIP`), and whether `MTK_SEC_USBDL` is set. Everything the brief assumes about "software root of trust already enforcing signatures" rests on this one makefile line, and the Basecamp record is consistent with either answer at different dates.
5. **Partly answered 12 Sep.** CVTE's description of compile-time signing with a hash gate against `efuse_iFitG520.img` "and the private key" places the MediaTek root key on CVTE's build system, and the `dev-keys` tag places the Android platform keys there too. The remaining question is whether ICON holds independent copies of each, and whether both key families move into the separate release-signing step requested in item 5 of the reply. Whether the ICON platform keys that sign the Android OTA and the MediaTek boot-chain keys (`root_prvk.pem`, `img_prvk.pem`,

- da_prvk.pem, epp_prvk.pem) are managed as one custody problem or two. Source F section 5 and 6 show the root public key is compiled into the preloader, the DA and LK, so a root rotation rebuilds all three; G3 must name a holder for each key, and K0 freezes all of them.
6. What efuse_iFitG520.img actually encodes. Source F section 7 lists Enable_SBC, Enable_DAA and Disable_Rom_Cmd as the three input.xml switches, and the preloader GFH config carries brom_magic_cmd_mode_permanent_dis, jtag_en and debug_en. No source in this set states the values CVTE used. The plan has been assuming SBC only; that is unverified until the XML and a read-back are on file.
 7. Whether BROM on MT8371 with eMMC ever falls back to the second preloader copy. Source F documents the fallback for NAND. If eMMC has none, the product has no preloader redundancy in either configuration and preloader_b is inert.
 8. The state of the 100 fused units: which firmware they carry, whether their serials and per-serial fuse read-backs from the factory-test check are already in ICON's hands, whether any have already been shipped or committed to customers, and whether they run the production OTA client and telemetry agent. P1 to P6 assume they are still at CVTE or ICON.
 9. Whether "sufficient test data" has an agreed definition. Section 3.3 proposes X1 to X7; without a signed definition the cohort period has no end and every MP lot ships unfused by default.
 10. Whether the OTA backend can target rings by fuse state and can hold a cohort-first ring ahead of the control group. Without that, the cohort cannot be made the first ring, and the control comparison cannot be run on the same transitions.
-

8. Open questions to CVTE, Malata and MediaTek

Plan B section 7 questions 1–16 are carried forward unchanged and should be sent as one letter on Day 1, quoting both chip designators (MT8371 / Genio 520 and MT8189 as the tool reports it). Add:

1. Can the MP line run unfused and switch to fused mid-lot without re-qualification, and what changes on the station when it does?
2. Will CVTE and Malata accept a key rotation and a regenerated fuse image before their first fused lot, and what is the lead time?
3. What is the per-unit depot cost and turnaround for a fused unit at each ODM's service path, and does either require an additional auth file or certificate for secure download?
4. To CVTE: provide the input.xml and preloader GFH configuration used to generate efuse_iFitG520.img, with the values of Enable_SBC, Enable_DAA, Disable_Rom_Cmd, brom_magic_cmd_mode_permanent_dis, jtag_en and debug_en, and a read-back from a first-article unit showing the same.
5. To MediaTek: does BROM on MT8371 attempt the second preloader copy (eMMC boot1) when boot0 fails to load or fails authentication? The Secure Boot Developer Guide V1.1 section 3.1 documents this for NAND only.
6. To CVTE: which MTK_SEC_BOOT and MTK_SEC_USBDL values are set in the VKC1_20260909 preloader project makefile?

Sent to CVTE on 12 September 2026 in ICON's reply declining eFuse programming on the next batch (answers pending):

1. Factory test to accept unfused units for this batch while still reading and logging eFuse state per serial (I6).
2. Confirm the unfused batch preloader is ATTR_SB00T_ENABLE / ATTR_SUSBDL_ENABLE, or state if it is ONLY_ENABLE_ON_SCHIP (covers question 22, A0-b).

3. Send `input.xml`, preloader GFH configuration and read-back logs for the 100 fused units (covers question 20).
4. Confirm the unfused batch is signed with the same root, image, DA and platform keys as the fused cohort so one OTA package serves both populations.
5. Confirm the build will be produced as `release-keys` through a signing step separate from compilation (G1); custody to be discussed separately.

Carried from the dev-keys analysis, not a blocker:

1. Confirm the 39 APKs on 0909 not signed with the ICON platform certificate are all expected third-party or vendor apps, and none is an ICON component that should carry the platform certificate but does not.

9. Traceability

This document	Source
Section 0 item 1, Section 1.1 conflicts 4 and 5	Feasibility study: programming modes table, risk analysis 1–4, recommendations 1 and 3
Section 1.1 conflicts 1, 2, 3, 6; glitch matrix IDs; kernel and build flag table; CTS/VTs modules	A/B Resiliency Test Plan v2.0 sections 3–6
Program history, risk register R1–R19, groups A–N, sample matrix, exit criteria, open questions 1–16	Closed-Config Brick-Resistance Test Plan r0.4 sections 2–7
No RTC, rollback resistance unavailable	Cesium 0831 Boot Log Analysis, items 1 and 6
Section 2.1 three-way table; preloader unverified under software RoT; <code>ATTR_SB00T_ENABLE</code> versus <code>ONLY_ENABLE_ON_SCHIP</code> ; key-rotation brick mode; DAA recovery constraint; conflicts 7 to 9; cases A0, A0-b, K0; assumptions 19 and 20	Software Root of Trust Report sections 1.1, 3, 4, 5.1 to 5.3
Verification of Source E; BROM secure boot flow and <code>SBC_EN</code> dependency; CERT1/CERT2 chain; <code>oemkey.h</code> into preloader, DA and LK; DAA AuthFile flow; NAND-only second preloader copy; <code>Disable_Rom_Cmd</code> , <code>jtag_en</code> , <code>debug_en</code> ; conflicts 10 and 11; E2 rescope; G7 extension; Day 1 action 5; assumptions 21 and 22; open questions 20 to 22	MT8391 MT8371 Android 15 Security Secure Boot Developer Guide V1.1, sections 2, 3.1, 4, 5.1, 5.2.1, 5.4, 6, 7

Prepared for internal ICON review. Contains no verbatim reproduction of vendor documentation. Not yet issued to CVTE or Malata.